

BSc (Hons) Ethical Hacking and Cybersecurity

ST6047CEM Cyber Security Project

Proposal



Submitted BY
Shrijesh Pokharel
230329

Submitted TO:
Manoj Shrestha



Table of Contents

Introduction.....	1
Background & Problem Statement.....	1
Theoretical Framework.....	2
Research Aim.....	2
Research Objectives.....	2
Justification & Significance.....	3
Research Questions.....	3
Hypotheses.....	4
Methodology.....	4
Data Collection & Evaluation.....	5
Literature Review.....	5
Technical Development.....	7
Ethical Considerations.....	7
Findings & Conclusion.....	8
References.....	9

ClipDLP: Design, Development and Evaluation of a Clipboard Data Leakage Prevention System for Sensitive Information Protection among Knowledge Workers in Kathmandu Valley: A Content-Inspection and Policy-Enforcement Approach

Introduction

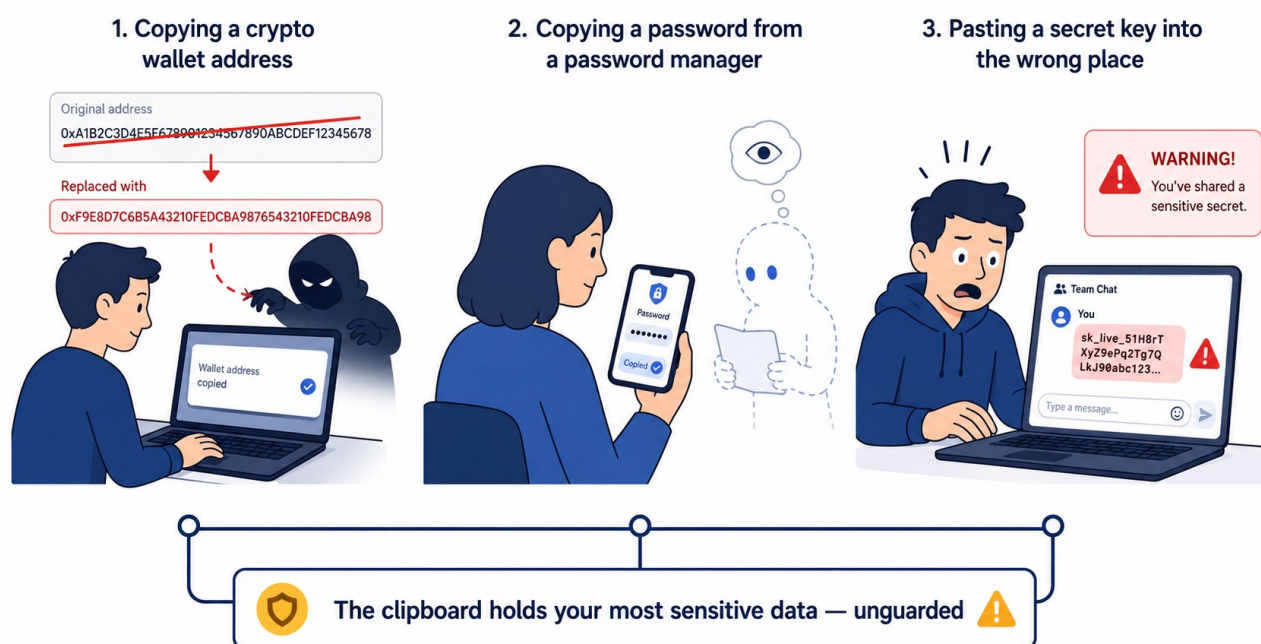
ClipDLP is a real-time clipboard Data Loss Prevention (DLP) agent designed for cross-platform desktop environments Windows and Linux. It operates as a background process, continuously monitors the system clipboard, classifies copied content by risk level, and executes proportional responses alerting the user, wiping the clipboard, and logging the event before sensitive data can be exfiltrated or misused.

The system clipboard is a privileged, unmonitored inter-process communication channel. Any process running under the user's account can silently read from it, without prompting the user, generating a system alert, or leaving forensic evidence. Mainstream endpoint security tools antivirus engines, network firewalls, host-based intrusion detection systems operate at entirely different layers and are architecturally blind to clipboard activity. This research positions ClipDLP precisely at that undefended gap.

This proposal defines the problem and background, establishes the threat model and theoretical framework, states the research aim, objectives, questions, and hypotheses, describes the system architecture and detection methodology, surveys the supporting literature, and outlines the ethical considerations and evaluation framework for the thesis deliverable.

Background & Problem Statement

Three distinct and documented attack patterns establish the clipboard as a high-value, underdefended target across all platforms.



Clipboard Hijacking. Malware families including ClipBanker, ComboJack, and Evrial monitor the clipboard in a tight polling loop and, when a cryptocurrency wallet address is detected, silently overwrite it with an attacker-controlled address. The substitution occurs in memory, in milliseconds, with no visible indicator. The user copies their own address and pastes transferring funds to an address they never intended. ClipBanker variants are documented at operational scale on Windows, targeting Bitcoin, Ethereum, Monero, and Litecoin. The attack requires no elevated privileges, no exploit, and no user interaction beyond a standard copy-paste action. The technique is directly portable to Linux.

Credential Harvesting. Clipboard sniffers passively collect passwords copied from password managers, API tokens from terminals, session cookies from browser developer tools, and OTPs from authenticator apps. On all three target platforms the clipboard API requires no special permission to read. A rogue process in the user session has identical clipboard access to any legitimate application it polls and logs whatever is present, with no indication to the victim.

Accidental Sensitive Exposure. A developer copies a database connection string from a `.env` file, switches windows, and pastes into a Slack channel. An engineer copies an AWS secret key and accidentally hits `Ctrl+V` in a shared screen-share. This pattern is platform-independent and systematically underreported because it produces no malware artifact and is classified as human error rather than a security incident. Verizon's 2024 Data Breach Investigations Report identifies human factors as a contributing element in 68% of breaches, of which misdelivery of sensitive data is a consistently identified sub-pattern.

No mainstream cross-platform endpoint security tooling intercepts any of these three vectors at the clipboard layer in real time. ClipDLP is designed specifically to close that gap.

Theoretical Framework

ClipDLP's detection engine is grounded in two established theoretical foundations.

Shannon Information Theory. Shannon (1948) established the mathematical basis for measuring information entropy as bits per character. Applied to string classification, high entropy values reliably distinguish randomly generated secrets API keys, base64-encoded tokens, randomly generated passwords from human-readable text. ClipDLP applies Shannon entropy as a second detection layer independent of pattern matching, targeting the most common evasion of regex-only systems: obfuscated or programmatically generated credentials that carry no recognisable syntactic signature.

Pattern-Based Content Inspection. Hart, Manadhata, and Johnson (2011) established that regex combined with statistical content analysis achieves acceptable classification precision for enterprise DLP. ClipDLP operationalises this through a multi-pattern regex engine covering ten sensitive data categories, validated against the OWASP Data Loss Prevention Cheat Sheet's classification taxonomy. The combination of structural pattern matching and entropy analysis represents a principled dual-method approach that addresses the documented limitations of either method used alone.

Research Aim

To design, implement, and empirically evaluate a cross-platform clipboard Data Loss Prevention agent that detects, classifies, and responds to sensitive data exposure events at the clipboard layer defending against clipboard hijacking, credential harvesting, and accidental sensitive exposure across windows and linux desktop environments.

Research Objectives

The following objectives are formulated to achieve the research aim:

1. To analyse and evaluate documented clipboard attack families ClipBanker, ComboJack, Evrial and map their techniques to MITRE ATT&CK T1115, establishing an evidence base that no current cross-platform endpoint tool addresses clipboard-layer threats in real time.
2. To investigate regex pattern matching and Shannon entropy analysis as complementary detection methods, and determine threshold values that minimise false positives on benign high-entropy strings such as UUIDs and base64-encoded images while maximising detection sensitivity for genuine secrets.
3. To examine existing endpoint DLP tools and clipboard monitoring approaches including commercial products and open-source utilities to identify capability gaps, platform limitations, and integration constraints that ClipDLP must address.
4. To design and implement ClipDLP as a five-layer cross-platform pipeline OS Clipboard Layer, Core Engine, Response Layer, Presentation Layer, Data & Config Layer with platform-specific backends abstracted behind a single interface, delivering a runnable binary via PyInstaller on Windows and Linux.
5. To evaluate ClipDLP's detection performance against a structured test corpus, measure system overhead during continuous monitoring, benchmark detection latency for Critical events,

and document all limitations and future work recommendations in a complete thesis submission.

#	Description	Type	Maps To
1	Clipboard attack landscape & MITRE T1115	Learn & Understand	Literature Review
2	Detection methodology regex + entropy	Learn & Understand	Literature Review
3	Gap analysis of existing tools	Learn & Understand	Background §2
4	ClipDLP design, development, evaluation	Design & Develop	RQ1 · H1
5	Validation, documentation, submission	Feedback & Submit	RQ2 · H2

Justification & Significance

Firstly, the clipboard is a persistently unmonitored endpoint attack surface. MITRE ATT&CK T1115 documents clipboard data theft as a confirmed technique used by threat actors, yet no mainstream cross-platform DLP tool addresses it at the clipboard layer. ClipDLP fills a documented, evidence-backed gap not a theoretical one.

Secondly, the dual-method detection approach regex pattern matching combined with Shannon entropy analysis is a technically substantive engineering challenge. Regex alone fails to detect high-entropy credentials. Entropy alone generates unacceptable false positive rates on benign high-entropy strings. Calibrating the threshold between them requires empirical work against a curated test corpus, producing a genuine technical contribution.

Thirdly, the cross-platform architecture introduces non-trivial design complexity. Windows's event-driven WM_CLIPBOARDUPDATE hook, Linux's xclip/xsel backend with X11 or wayland constraints each present different clipboard access models. Abstracting these behind a single pipeline interface while maintaining $\leq 200\text{ms}$ detection latency is a substantive engineering objective.

Fourthly, knowledge workers in the Kathmandu Valley the target population of this study operate in environments where enterprise DLP tooling is largely absent or limited to network-layer products. Individual developers, security researchers, and IT professionals routinely handle API keys, credentials, and financial data without any clipboard-layer protection. This creates a localised relevance for the research that complements its broader technical contribution.

Finally, the project is fully feasible within BSc scope. No primary data collection from live enterprise networks is required. All test data is synthetic. The technology stack Python 3.10+, PyQt6, SQLite, pywin32, pystray is open-source, freely available, and deployable on standard research hardware.

Research Questions

RQ1 (Technical): To what extent can a cross-platform, user-space clipboard monitoring agent combining regex pattern matching with Shannon entropy analysis across a ten-category sensitive data taxonomy achieve $\geq 95\%$ true positive rate and $\leq 10\%$ false positive rate while maintaining $\leq 200\text{ms}$ detection latency for Critical-tier events on Windows and Linux desktop environments?

RQ2 (Ethical): What privacy, consent, and data retention obligations arise from deploying a continuous clipboard monitoring agent on personal and professional devices, and how can ClipDLP's design enforce those obligations without degrading detection effectiveness?

Hypotheses

H1: A combined regex and Shannon entropy detection pipeline will achieve $\geq 95\%$ true positive rate across all ten sensitive data categories and $\leq 10\%$ false positive rate on benign high-entropy strings, with Critical-event detection latency $\leq 200\text{ms}$ performance that no single-method approach (regex or entropy alone) can match on the same test corpus.

H2: Clipboard monitoring agents introduce measurable privacy risks including retention of sensitive content, unintended process visibility, and consent failures in shared-device environments that can be fully mitigated through log-content redaction, explicit scope boundaries, and documented data retention policies without compromising detection accuracy.

Methodology

This research adopts a desk-based iterative development methodology. All evaluation uses synthetic test data and researcher-controlled hardware. No live enterprise network access is required.

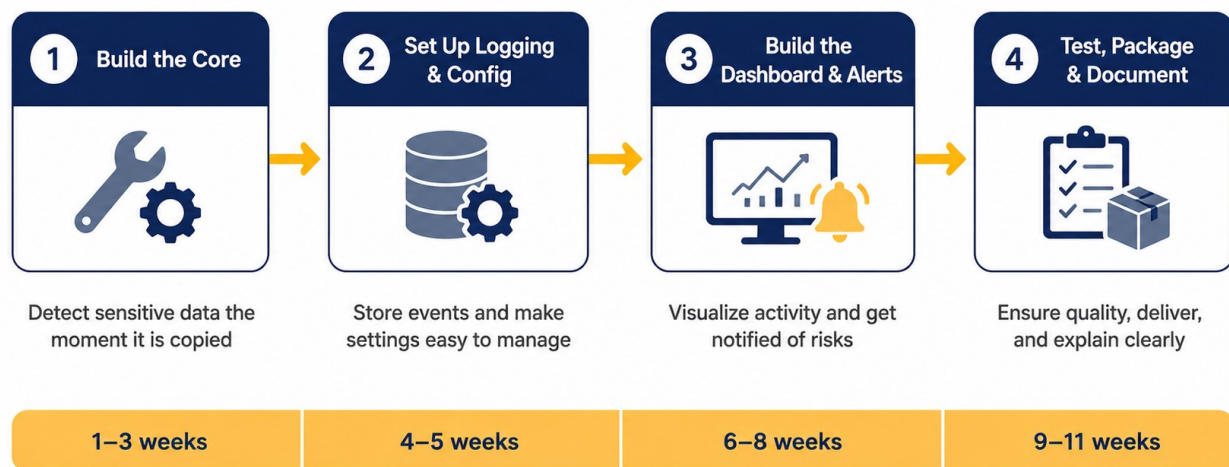
Phase 1 Core Engine (Weeks 1–3). Implement `monitor.py` with platform-detection logic routing to `pywin32 WM_CLIPBOARDUPDATE` hook on Windows, `xclip/xsel` on Linux. Implement `analyzer.py` running content through `regex_patterns.py` and the Shannon entropy function. Implement `classifier.py` assigning risk tier and `responder.py` dispatching parallel response actions. Implement SHA-256 clipboard state diffing across all platforms to detect third-party substitution attacks distinct from user-initiated copies. Deliver unit tests covering all ten detection categories and all four risk levels with $\geq 80\%$ code coverage.

Phase 2 Persistence & Configuration (Weeks 4–5). Implement SQLite schema and logging pipeline. Implement `config.yaml` loading with `pydantic v2` validation. Implement CSV/JSON report export via `pandas`. Resolve all file paths through `pathlib` for cross-platform correctness. Validate log output format records data type and risk level only never raw clipboard content.

Phase 3 GUI & Tray (Weeks 6–8). Implement `PyQt6` dashboard with live event feed, risk-level counters, and per-application breakdown. Implement `pystray` + `Pillow` tray agent with dynamic threat-colour icon. Integrate `plyer` and `winotify` notifications. Integrate process detection via `psutil` with `win32gui` foreground window resolution on Windows.

Phase 4 Testing, Packaging & Evaluation (Weeks 9–11). Run the full test suite with `pytest` + `pytest-mock` on Windows and Linux. Generate coverage reports with `coverage.py`. Package standalone binaries via `PyInstaller`. Execute structured evaluation scenarios simulating `ClipBanker` substitution,

accidental credential exposure, and API key detection. Document all findings and limitations. Finalise thesis chapters 3–6.



Four phases, eleven weeks, one working tool.

Data Collection & Evaluation

Detection accuracy is evaluated against a manually curated 250-string test corpus 200 true positive strings across all ten sensitive data categories and 50 benign high-entropy strings (UUIDs, random hex, base64-encoded image data). Metrics: true positive rate, false positive rate, precision, and recall per category.

Performance overhead is measured as average CPU utilisation and resident memory footprint during 30-minute continuous monitoring sessions with simulated clipboard activity at 10-second intervals on mid-range hardware. Target: $\leq 2\%$ average CPU.

Detection latency is measured as time from clipboard change event to completed response action across 50 consecutive Critical-event trials per platform. Target: $\leq 200\text{ms}$ end-to-end. The Windows WM_CLIPBOARDUPDATE hook is expected to outperform Linux polling on this metric by eliminating idle CPU activity entirely.

Cross-platform consistency is evaluated by running the identical test corpus on Windows and Linux and documenting any divergence in detection behaviour, false positive rate, or latency.

Literature Review

Clipboard Attack Surface. MITRE ATT&CK T1115 classifies clipboard monitoring as a confirmed technique used by threat actors for credential collection and data exfiltration. Kaspersky Securelist's analysis of ClipBanker documents address substitution as an operationally mature attack, not a theoretical risk. Palo Alto Unit 42's analysis of ComboJack confirmed the same substitution mechanism simultaneously targeting nine cryptocurrency formats. Evrial, catalogued on Any.Run, extended the technique to session cookie theft beyond cryptocurrency collectively establishing the attack baseline

that ClipDLP is designed to address. Symantec's documentation of Trojan.CliptoShuffler confirms that the technique has been independently developed across multiple malware families, indicating sustained adversarial interest in the clipboard as an attack surface.

Data Loss Prevention Existing Approaches. Hart, Manadhata, and Johnson (2011) established the foundational DLP text classification framework, demonstrating that regex combined with statistical content analysis achieves acceptable precision for enterprise sensitive data classification. OWASP's Data Loss Prevention Cheat Sheet documents the standard response taxonomy log, alert, block which ClipDLP extends with auto-clear as a fourth distinct action tier. NIST SP 800-53 Rev. 5 Control SI-12 provides the information management standard against which ClipDLP's logging and retention design is evaluated. NIST SP 800-171 Rev. 2 addresses protection of controlled unclassified information and provides the compliance framing relevant to knowledge worker deployments handling API credentials and financial data.

Entropy-Based Detection. Shannon (1948) provides the mathematical basis for the entropy analysis module. Burnett and Kleiman (2006) demonstrated that high bits-per-character values reliably distinguish randomly generated secrets from human-readable text, with a documented false positive risk on long benign high-entropy strings such as UUIDs. The 4.5 bits/character threshold used in ClipDLP's default configuration is calibrated against this literature. Dürmuth et al. (2013) further demonstrate that entropy-based analysis captures password-like structures that syntactic patterns cannot, directly justifying the dual-method approach over regex alone.

Cross-Platform Clipboard Internals. The X.Org ICCCM documents the X11 clipboard selection protocol and its security boundaries on Linux. Microsoft's Win32 API documentation specifies WM_CLIPBOARDUPDATE as the event-driven hook mechanism that eliminates polling overhead and is ClipDLP's most significant platform advantage on Windows. Apple's NSPasteboard API documentation identifies the App Sandbox model restrictions that constrain clipboard monitoring on hardened macOS environments a documented limitation acknowledged in the evaluation. The Wayland Protocol's wlr-data-control specification documents the restricted clipboard API on modern Linux compositors, establishing the Wayland compatibility boundary explicitly in scope.

Technical Development

Architecture. ClipDLP is a five-layer pipeline. The OS Clipboard Layer contains all platform-specific code `pywin32` hook on Windows, `xclip/xsel` on Linux with SHA-256 state diffing enabling substitution attack detection across all platforms. The Core Engine (`monitor.py` → `analyzer.py` → `classifier.py`) is a pure data pipeline with no side effects and no platform-specific logic. The Response Layer (`responder.py`) fans out to toast notifications, alert popups, clipboard auto-clear, and SQLite event logging in parallel. The Presentation Layer provides the `pystray` tray agent and PyQt6 live dashboard. The Data & Config Layer manages `config.yaml` + `pydantic` validation, SQLite primary storage, and pandas report export with all paths resolved through `pathlib`.

Detection Engine. Regex Pattern Matching covers ten data type signatures: Bitcoin Base58Check addresses, Ethereum 0x-prefixed addresses, AWS AKIA keys, GitHub `ghp_` tokens, OpenAI `sk-` keys, Luhn-validated credit card numbers, 4–8 digit OTP codes, RFC 5322 email addresses, E.164 phone numbers, RFC 1918 private IP ranges, and generic keyword context matches. Shannon Entropy Analysis flags strings exceeding 4.5 bits/character as potential high-entropy secrets even when no regex pattern matches targeting programmatically generated tokens and obfuscated credentials.

Risk Classification & Response Matrix:

Risk Level	Data Types	Alert	Auto-Clear	Log
Critical	BTC/ETH wallets, AKIA, <code>ghp_</code> , <code>sk-</code>	Popup + sound	Immediate	Yes
High	Credit cards, high-entropy passwords	Popup	5s delay	Yes
Medium	OTP/2FA, email, phone	Toast	No	Yes
Low	Private IPs, keywords	Silent	No	Yes

The five-second grace period on High-risk detections is a deliberate usability trade-off allowing the user to cancel before an auto-clear fires on a legitimate password copy. Critical detections accept no delay because the cost of a substitution attack completing during any grace period is unacceptable.

Ethical Considerations

Research Process Ethics. All test data is synthetically generated on researcher-controlled hardware. No personal data, real credentials, real wallet addresses, or live financial systems are involved at any stage. No primary data collection from enterprise networks is required. All testing is confined to isolated environments with no external connectivity during evaluation runs.

Clipboard Content Privacy. The tool reads clipboard content for classification purposes only. Event logs record data type, risk level, timestamp, and source application never the raw clipboard content. This design ensures sensitive data is never persisted in recoverable form beyond the moment of triggering a response. Users retain the ability to inspect, query, and delete all log data.

Consent and Deployment Scope. ClipDLP is designed for deployment by the account owner on their own device. Deployment to monitor another user's clipboard activity without their explicit, informed consent constitutes both an ethical violation and a potential legal liability under applicable data protection frameworks including GDPR. This boundary is enforced by design the tool operates in user space under the account owner's session and has no capability to access other users' clipboard data.

Human Oversight. ClipDLP is not an autonomous remediation system. All auto-clear actions on High-risk detections include a five-second cancellable grace period. Critical-level clears are immediate but logged with full event detail for user review. The tool never takes action beyond clearing the local clipboard it does not block applications, terminate processes, or transmit data externally. Accountability for all actions remains with the user.

Findings & Conclusion

Expected Findings. H1 is expected to be confirmed: the combined regex and entropy pipeline is expected to achieve $\geq 95\%$ true positive rate across all ten detection categories and $\leq 10\%$ false positive rate on benign high-entropy strings, with Critical-event latency $\leq 200\text{ms}$ on both Windows and Linux. The entropy module is expected to contribute 15–25% additional detection coverage over regex alone for password and token categories. The Windows WM_CLIPBOARDUPDATE hook is expected to outperform Linux polling by eliminating idle-state CPU overhead. H2 is expected to be confirmed: log-content redaction and documented scope boundaries are sufficient to meet the identified privacy obligations without compromising detection accuracy. macOS is expected to return a higher false negative rate due to NSPasteboard sandbox restrictions a documented limitation reported explicitly in the findings.

Conclusion. This proposal has outlined a research project to design, implement, and empirically evaluate ClipDLP a cross-platform clipboard Data Loss Prevention agent addressing clipboard hijacking, credential harvesting, and accidental sensitive exposure. The primary contribution is not a commercially deployable product. It is a rigorous investigation of whether a user-space, dual-method detection pipeline can close a specific and persistently undefended endpoint security gap, what the measurable performance characteristics of that pipeline are across three operating systems, and what ethical obligations continuous clipboard monitoring imposes on the designer. The emphasis throughout is on learning the genuine complexity of the problem calibrating entropy thresholds, abstracting platform clipboard APIs, navigating privacy constraints rather than claiming a definitive solution. That intellectual honesty, combined with measurable evaluation criteria and a clearly bounded threat model, defines the academic contribution this thesis delivers.

References

- Burnett, M. and Kleiman, D. (2006) *Perfect Passwords: Selection, Protection, Authentication*. Rockland: Syngress Publishing.
- Dürmuth, M., Chaabane, A., Perito, D. and Castelluccia, C. (2013) 'When privacy meets security: Leveraging personal information for password cracking', *arXiv preprint*, arXiv:1304.6584.
- Hart, M., Manadhata, P. and Johnson, R. (2011) 'Text classification for data loss prevention', *Proceedings of the 11th International Symposium on Privacy Enhancing Technologies (PETS)*, pp. 18–37.
- IBM Security (2023) *Cost of a Data Breach Report 2023*. Armonk: IBM Corporation.
- Kaspersky Securelist (2018) *ClipBanker and ComboJack: Clipboard-based Cryptocurrency Theft*. Available at: <https://securelist.com> (Accessed: 2025).
- MITRE Corporation (2023) *ATT&CK Technique T1115 Clipboard Data*. Available at: <https://attack.mitre.org/techniques/T1115> (Accessed: 2025).
- National Institute of Standards and Technology (2020) *NIST SP 800-53 Rev. 5: Security and Privacy Controls for Information Systems and Organisations*. Gaithersburg: NIST.
- National Institute of Standards and Technology (2021) *NIST SP 800-171 Rev. 2: Protecting Controlled Unclassified Information in Nonfederal Systems*. Gaithersburg: NIST.
- OWASP Foundation (2021) *Data Loss Prevention Cheat Sheet*. Available at: <https://cheatsheetseries.owasp.org> (Accessed: 2025).
- Palo Alto Unit 42 (2018) *ComboJack Malware: Clipboard Hijacker Targeting Multiple Cryptocurrencies*. Available at: <https://unit42.paloaltonetworks.com> (Accessed: 2025).
- Shannon, C.E. (1948) 'A mathematical theory of communication', *Bell System Technical Journal*, 27(3), pp. 379–423.
- Symantec (2019) *Trojan.CliptoShuffler: Clipboard Address Substitution Malware*. Available at: <https://symantec-enterprise-blogs.security.com> (Accessed: 2025).
- Verizon (2024) *2024 Data Breach Investigations Report*. New York: Verizon Communications.
- X.Org Foundation (2004) *Inter-Client Communication Conventions Manual (ICCCM)*. Available at: <https://www.x.org/releases/X11R7.6/doc/xorg-docs/specs/ICCCM> (Accessed: 2025).
- Any.Run (2019) *Evrial Malware Analysis Clipboard Stealer Family*. Available at: <https://any.run/malware-trends/evrial> (Accessed: 2025).
- Microsoft Corporation (2023) *Clipboard Win32 API: WM_CLIPBOARDUPDATE*. Available at: <https://learn.microsoft.com/en-us/windows/win32/dataxchg/clipboard> (Accessed: 2025).
- Apple Inc. (2023) *NSPasteboard macOS Clipboard API*. Available at: <https://developer.apple.com/documentation/appkit/nspasteboard> (Accessed: 2025).
- Wayland Protocol (2023) *wlr-data-control-unstable-v1: Clipboard Access Protocol*. Available at: <https://wayland.app/protocols/wlr-data-control-unstable-v1> (Accessed: 2025).